Data Sources

NVD — NVD feeds 2016–2025

KEV — CISA KEV catalogue

CPE — Vendor | product IDs

237,705
CVE records after removing rejected (2016–2025)

~105 / day
new CVEs in 2025 (47,946; peak 483 on one day)

1,367
CVEs exploited in the wild (CISA KEV)

Fields per CVE
description · CPE config · CNA vendor/product · CVSS v3.x · CWE

Data Normalisation

Record Filtering → **Field Extraction** → **Token-safe Truncation**

Drop **rejected** CVE records from NVD API 2.0 mirror (Fraunhofer FKIE)

Keep **description**, CPE, vendor|product, CVSS v3.x vector, CWE

Truncate description to **300 tokens** so the instruction is never cut

Model input vs. label source (kept independent)

Text only
→ seen by the models

vendor | product
→ used only for labels

Reference Labelling

Rule set on structured vendor | product pairs

OEM	**Vehicle platforms, connected-car services**
T1	**Infotainment, head units, telematics, ECUs**
T2	**Automotive software & silicon (QNX, SoCs)**
EVSE	**EV chargers & OCPP back-ends**
AFT	**Dash cams, GPS trackers, OBD tools**
×	**Exclude look-alikes (e.g. “Tesla” GPUs)**
Hidden	**>10 affected platforms (n = 123)**

Automotive Slice Profile

Automotive CVEs per year

2022	2023	2025
15	85	172

driven by EV charging (67) and T1 head units (53) in 2025

CVEs per supply-chain layer

Layer	CVEs
OEM	92
T1	95
T2	40
EVSE	164
AFT	78

469
automotive CVEs
79 vendors

29.6%
adjacent network
(NVD 2.3%)

17.0%
physical access
(NVD 0.9%)

34.7%
access / auth CWE
(NVD 21.6%)

0
in CISA KEV
median CVSS 7.5

Temporal Split and Benchmark Tasks

TRAIN 2016–2022
124,906 CVEs · supervised parts only

TEST 2023–2025
future CVEs

T1 · Relevance triage
3,000 CVEs, 342 automotive (11.4%)

T2 · Supply-chain layer
342 automotive CVEs, 5 classes

T3 · Attack vector & severity
326 with CVSS v3, 4 classes each

T4 · Weakness family
265 CVEs, 6 CWE families

T5 · Exploitation
519 KEV CVEs + 2,481 others

Hidden exposure
110 multi-platform bulletins, separate

Supervised baselines
fit on 2016–2022 labels only

Zero-shot LLM
no training labels at all

Same test set
all methods on 2023–2025 CVEs

LLM-based CTI Pipeline

Algorithm 1 · per CVE batch

① Pre-filter
TF-IDF + logistic regression
word 1–2-grams, char 3–5-grams
trained on 2016–2022
rank batch, forward top $\lceil \rho |C| \rceil$

→ **② LLM Triage**
FLAN-T5 base (250M) / large (780M)
zero-shot, runs locally on CPU
“Relevant to the automotive supply chain?”
$r = s_{yes} - s_{no} > 0$

→ **③ Calibration**
Contextual calibration with 3 content-free inputs:
`“N/A” · “” · “A vulnerability was found.”`
$\tilde{s}_k = s_k - \bar{s}_k$

→ **④ Enrichment**
for each positive CVE:
- supply-chain layer
- attack vector
- weakness family
- severity

arg max over option scores

Option scoring (mean token log-likelihood)

$$s_k(x) = 1/|a_k| \, \Sigma_t \log p_\theta(a_{k,t} \mid x, a_{k,<t})$$

deterministic · one encoder pass per CVE

Prompts (fixed before testing)

Plain
road vehicle, component or EV charger?

Taxonomy
defines 5 layers + look-alikes

Hybrid Fusion & Baselines

Hybrid fusion

TF-IDF prob. ⊕ **LLM margin**

Triage: mean of rank-normalised LLM margin and TF-IDF probability
Enrichment: $\tfrac{1}{2}\,\mathrm{softmax}(8\tilde{s}) + \tfrac{1}{2}\,g(d)$

Baselines

- **Keyword lexicon (~50 terms)**
- **TF-IDF + LR (supervised)**
- **Majority class**
- **CVSS base score**

Evaluation

AUROC · **AUPRC** · **Precision / Recall / F1**

P@100 & R@300 · **Accuracy** · **Macro-F1**

Cohen’s Kappa · **McNemar Test** · **Bootstrap 95% CI**

Latency (s / CVE) · **Paired Bootstrap Test** · **Throughput (CVEs / h)**

4-vCPU VM · 15 GB RAM · no GPU · batch 16 · FP32

Results and Error Analysis

T1 triage · AUROC (2023–2025)

Method	AUROC
Keyword lexicon	0.801
TF-IDF + LR	0.934
FLAN-T5-base	0.863
FLAN-T5-large	0.947
Hybrid	**0.965**

Recall per layer at native threshold

	OEM	T1	T2	EVSE	AFT
FLAN-T5-large	.98	.94	.48	.67	.70
TF-IDF + LR	.50	.13	.10	.05	.02

Failure modes

Prompt sensitivity
taxonomy prompt: AUROC 0.809

Label-option bias
“critical” for 77% of CVEs

Hidden exposure
recall ≤ 0.09 for all text models

Real-Time Deployment

Best Design: Hybrid Pipeline
↓
Local CPU Inference
4 vCPU · 15 GB RAM · no GPU
no product data leaves the organisation

⚠ Ranked alert (example)
Input: new NVD CVE description
Relevance: r > 0 → automotive
Layer: EVSE · **Vector: Adjacent** · **CWE: Access/auth**
Route: analyst queue (P@100 = 1.00)

1.14 s
per CVE, FLAN-T5-large

3,164 / h
CVEs on 4 CPU cores

9.2 min
busiest day of 2025 (483 CVEs)

57% fewer
LLM calls with top-43% pre-filter
(F1 0.79, P 0.83, R 0.75)

Vehicle SOC / PSIRT

Affected Supplier

Supports UN R155 / ISO/SAE 21434
lifetime threat monitoring